

CompTIA Server+

Data Security Concepts

- Introduction
 - Lab Topology
 - Exercise 1 - Password Management for BIOS, UEFI, & Bootloader
 - Exercise 2 - Data Storage and Encryption Paradigms
 - Exercise 3 - Business Impact of Data Security
 - Review
-

Introduction

Server+

BIOS/UEFI

Encryption

Data Lifecycle Management

Data at Rest

Data in Transit

Welcome to the **Data Security Concepts** Practice Lab. In this module, you will be provided with information on different security concepts for data.

In this lab, you will look at the security that should be applied to the computer's boot process, how data is handled, and managing risk. Data has become increasingly important in today's computer age, and some steps need to be taken to protect it and ensure its safety.

Learning Outcomes

In this module, you will complete the following exercises:

- Exercise 1 - Password Management for BIOS, UEFI, & Bootloader
- Exercise 2 - Data Storage and Encryption Paradigms
- Exercise 3 - Business Impact of Data Security

After completing this module, you should have further knowledge of:

- BIOS/UEFI Password
- Bootloader Password
- Physical Location & Retention Policies
- On-site Data Storage
- Off-site Data Storage
- Encryption
- Encryption Algorithms
- Data Value Prioritization
- Data Lifecycle Management
- Cost of Security Vs. Risk

Exam Objectives

The following exam objectives are covered in this module:

3.1 Summarize data security concepts

- Encryption paradigms
- Retention policies
- Data storage
- UEFI/BIOS passwords
- Bootloader passwords
- Business impact

Lab Duration

It will take approximately **1 hour** to complete this lab.

Help and Support

For more information on using Practice Labs, please see our **Help and Support** page. You can also raise a technical support ticket from this page.

Click **Next** to view the Lab topology used in this module.

Lab Topology

This module contains supporting materials for Server+ (SK0-005).

Click **Next** to proceed to the first exercise.

Exercise 1 - Password Management for BIOS, UEFI, & Bootloader

A time that a computer can be vulnerable and is often overlooked is during the boot process. During the boot process, the computer must first run tests on itself and make sure everything is functioning properly. Basic Input Output System and its updated Unified Extensible Firmware Interface make this possible.

In this exercise, you will learn about the importance of protecting this configuration area.

Learning Outcomes

After completing this exercise, you should have further knowledge of:

- BIOS/UEFI Password
- Bootloader Password

Your Devices

This exercise contains supporting materials for Server+ (SK0-005).

BIOS/UEFI Password

Basic Input Output System and Unified Extensible Firmware Interface are firmware used to boot the computer and operating system hardware and manage the data flow to the hardware. BIOS was introduced in 1975, and UEFI was introduced in 2005 and was an update to the BIOS system. It allows for the use of a mouse and a user interface similar to the graphical user interface you experience in today's computing. Both are firmware embedded on the motherboard's Erasable Programmable Read Only Memory (EPROM) chip. This chip does not require electricity to store the information and can be updated by a process known as flashing. It is crucial during this flashing process that electricity does remain constant or permanent damage to the chip can occur. These updates offer security patches, additional functionality of

hardware, and other improvements. During the boot process, BIOS/UEFI starts the Power On Self-Test (POST), where the computer checks for attached peripherals and functionality.

After the computer passes the POST, the BIOS/UEFI will initiate the bootstrap loader, which will locate and load the required operating system from the selected media in the boot order. To access the BIOS/UEFI, the menu would need to be accessed at the start of the PC. When the manufacturer splash screen is displayed, it will display what key needs to be pressed to enter the BIOS/UEFI menu. Common keys that are pressed are F1, F8, ESC and Enter. Once in this menu, users can make many changes to the computer, including date and time, the boot order, hard drive settings, CPU settings like overclocking, enable/disable virtualization, enable/disable RAID, Audio Settings, Video Settings, and many more.

Many system-critical configurations can be changed, so it is critical to implement security measures. Both BIOS and UEFI allow the administrator to create a password to enter the BIOS/UEFI menu. It is highly recommended that this be created as soon as possible.

Bootloader Password

A bootloader password is a system password required to initiate the computer's boot process in a PC with a Linux operating system. This will be configured through a series of commands in the terminal to adjust the GRUB file and add the password. Another benefit besides stopping unwanted booting is that the password will also help protect single-user mode. This mode can allow hackers to reset passwords, including the root password, to gain administrative access to the PC. Setting the bootloader password will only work locally on the PC. It will not work with a remote connection, and if administering it remotely, the password would have to be entered by another employee at the office for initial access and any restarts due to updates. It is also imperative that this password is not forgotten because it will prevent booting into the operating system again.

Exercise 2 - Data Storage and Encryption Paradigms

Over time there has been a shift in what is deemed valuable. In today's fast-paced computing world, data, specifically data tied to people, has become increasingly valuable.

In this exercise, different tactics to use, store, and keep data safe will be discussed.

Learning Outcomes

After completing this exercise, you should have further knowledge of:

- Physical Location & Retention Policies
- On-site Data Storage
- Off-site Data Storage
- Encryption
- Encryption Algorithms

Your Devices

This exercise contains supporting materials for Server+ (SK0-005).

Physical Location & Retention Policies

Depending on the nature of the data, some forms may need to be managed by the organization and stored on the premises. Some data types are more sensitive than others. Organizations will commonly store three categories of data on the premise:

- Personally Identifiable Information (PII)
- Protected Health Information (PHI)
- Payment Card Industry Data Security Standard (PCI DSS)

Data that is unique to them, such as a trade secret, may also be kept on premises. Even if cloud computing is secure, the data is still in the hands of the cloud provider if you store it there, which may not be acceptable based on laws, regulations, and a company's policies.

Other criteria must be observed for how long the data must be maintained before being discarded. This will differ based on the country and state regulations. Once checked, policies for the various data kinds the business has can be defined. When creating these standards, keep things basic and clear so that staff may follow them. Some businesses may look at the longest amount of time it has to store data and use that as the universal number for convenience. Some businesses will lack the capacity to do so due to the required backup space. Each organization must develop its own policies and procedures for deciding what data to keep and when to discard it.

On-site Data Storage

On-site data storage is data stored in the same location as the primary device. They are stored there so users can easily access them and quickly restore their data. Hard drives or tape drives are usually used to store the data. There is software available that can automate the procedure and keep data backups. One advantage of using such a system is that the business is fully

responsible for data preservation and security when it uses on-site data storage. One of the drawbacks is that in the event of a catastrophe, there is a possibility that all the data may be lost.

Off-site Data Storage

Data kept off-site in a separate place is called off-site data storage. Both examples are either a centralized site where all data tapes and disks are delivered to and stored for the needed amount of time or a situation in which a cloud provider is utilized. When a person uses cloud services, their data is almost always kept on a server in a data center. The information that is kept will determine whether cloud services can be utilized, or the company must always maintain full control of its data. Cloud security can be compromised, which must be considered a potential risk even though the cloud's data centers are quite well protected. This kind of data backup is necessary for a catastrophic natural event. The data can be retrieved from any location with an internet connection, making it feasible to get the business back up and running as quickly as possible.

Encryption

Servers are becoming increasingly important to many businesses these days. As with desktop PCs and laptops, drives should be encrypted to ensure that they cannot be accessed if removed and taken. Entire drives can be encrypted using programs such as BitLocker.

Data at Rest

Data at Rest is data that is being stored and is not in current use. This can be on a server, an external drive, a thumb drive, a tape drive or other media used to store data. This category includes the current copy of data and any backup copies or archived copies of data. It is critical to encrypt this data to protect it from unauthorized exposure and to prevent data leakage.

There are programs that can encrypt single files, folders, or entire drives. Programs like EFS and Bitlocker are built into windows, or there are 3rd party vendors like Veracrypt, 7-zip, File Vault and many others that offer similar services. By encrypting the data, a user would not be able to see the data unless they had the decryption keys. A general rule is that if encrypting the entire drive is your sole option, even if it is simply because one file requires it, you should do so. It is preferable to encrypt that file and all others rather than leaving that one file unprotected. This contributes to the data's confidentiality, integrity, and authenticity.

Data in Transit

Data in transit is the data that is being moved from one place to another. By nature, unless encryption is applied, many networking protocols will send information in clear text. For instance, HTTP, used for web browsing and internet access, will run on default port 80 and is unsecure. With the addition of encryption provided by SSL/TLS, HTTP becomes HTTPS operating on default port 443. Increased security was required due to our reliance on the internet for things like shopping and banking. Login credentials and financial information sent in plain text were a major vulnerability to sniffing, man in the middle, and eavesdropping attacks.

SSL/TLS uses a public and private key pair and a certificate created and managed by a certificate authority to verify its validity and authenticity. Public Key Infrastructure, or PKI, will take the information sent and encrypt it using the public key. The information will be sent over the internet or through the network if it is local and then decrypted once received by the private key. The owner only knows the private key, and the public key is freely shared through the certificate.

Another form of protection for data in motion would be the use of Virtual Private Networks (VPN). A VPN makes it possible to use the existing infrastructure of the internet more securely. It will require using a VPN Server that will act as an intermediary for a configured end-user device. VPN helps to provide anonymity while browsing, encryption of the information, and safe public use. The end user device will connect to the VPN Server and authenticate by creating a tunnel. Once the tunnel is created, the data is sent, and the server applies the necessary encryption for all data sent and received. Each packet will be encapsulated inside another packet, which means each packet will have an outer wrapper that will provide additional encryption.

Encryption Algorithms

When it comes to encryption, there are some different options available:

Symmetric Encryption

Symmetric Encryption, also known as Secret Key Encryption, is encryption that uses the same “key” to encrypt and decrypt the data. Because of the simplicity of smaller keys, less space will be needed, encryption and decryption are faster, and there is a low processing cost.

A hurdle that needs to be overcome when using Symmetric is safely getting the key to the other party using it. Due to this, Symmetric Encryption often does the encryption and is then paired with Asymmetric Encryption to deliver. The Advanced Encryption Standard, the recommended encryption standard by the Department of Defense, uses key sizes of 128, 192, or 256 bits.

Asymmetric Encryption

Asymmetric encryption, often known as Public Key Infrastructure, is a type of encryption that encrypts and decrypts data using public and private keys. The public key, private key, and certificate are created and maintained by a server known as a certificate authority. The certificate can be found in the web browser's address bar. Each browser is different but checks for a lock that, when clicked, will allow you to access the certificate. When the certificate is viewed, it will display who it belongs to, who issued it, and the date range for which it is valid. When you click on the certificate's details, you'll see the version, serial number, and encryption algorithm utilized. The public key is also available here. This public key is paired with a private key owned by an individual or business. The end user's computer will use the public key to encrypt the message when information is sent. That message will be decrypted with the owner's private key and stored on the server. This is also the key to digital signatures. This validates the sender of the information and can be used to create non-repudiation and verify authenticity.

Asymmetric encryption can also be used to deliver keys. If symmetric encryption is utilized, asymmetric encryption can reliably send the keys needed to decipher the encrypted data. The recommended key size for asymmetric encryption is 2048 bits or more. Because of the use of longer keys and stronger ciphers, asymmetric is deemed safer than symmetric. The drawback of asymmetric encryption is that the cost of processing to encrypt and decrypt data is considerable. This means that these procedures will take more time and energy to complete than symmetric encryption. Also, the encrypted data cannot be decoded if that private key is lost.

Exercise 3 - Business Impact of Data Security

In the last exercise, the value of data and different methods of keeping it safe were discussed. In this exercise, you will explore how to determine valuable data, how to deal with that data from start to finish, and how to look at cost vs. security.

Learning Outcomes

After completing this exercise, you should have further knowledge of

- Data Value Prioritization
- Data Lifecycle Management
- Cost of Security Vs. Risk

Your Devices

This exercise contains supporting materials for Server+ (SK0-005).

Data Value Prioritization

Data Value Prioritization is the process of assessing the different data types within the business and determining their importance of it. A company can determine what it is required to keep, how many copies of each item, and where they must be stored by following these steps. Also, as important, businesses will know what data they do not need to keep, saving them valuable money on storage drives or storage in the cloud. Very important data that needs to be retained will be part of the backup process. Rules applied to the data retention will be determined, and the data can be stored and archived.

Data Lifecycle Management

The process of managing data throughout its existence, from the moment it is first recorded to the moment it is deleted, is referred to as "Data Lifecycle Management." There are five phases of data lifecycle management:

- Data production
- Data storage
- Data utilization
- Data archiving
- Data disposal

The creation of data comes from a wide variety of sources, and it will be necessary to classify the data in order to determine what should be retained. In the data storage process, the format in which the data will be stored is determined. Common form factors data will be stored on are a hard drive, a tape drive, a server or in the cloud. Other factors that have to be considered during this stage are whether the data requires encryption to be stored. Do you need to keep a few different copies of the data? Is there any kind of protocol that needs to be followed when storing the data?

Utilization of the data would be the third stage. After determining the reason for which the data will be used, a company may decide to employ the assistance of computers in order to classify and organize the data for use in business activities such as marketing. Another illustration of this would be the company's requirement to restore data from a backup. At the end of Stage 4, the data will have been archived because it is no longer being used. It will be removed from the production that is now underway and put into storage until it is required or until stage 5 is reached, at which point it will be deleted.

Cost of Security Vs. Risk

When evaluating risk, businesses will use four main ways to deal with risk:

- Risk Avoidance - This is when the risk is too great and will need to be avoided. For instance, if a popular program were available but exposed data to unnecessary risk, a business would likely stop using that program and possibly find another.
- Risk Acceptance - It is when a business understands and accepts the risks. Not all risk is created equal, and if the likelihood of an incident happening is low or the impact is low, businesses may decide to accept the risk.
- Risk Mitigation - This is about putting something in place to lessen the likelihood of the risk. For instance, stateful firewalls and intrusion prevention systems lessen the chances of a breach and are mitigation techniques.
- Risk Transference - Companies will often take the risk and pass it off to another company. Insurance is a good example of this, and hiring a 3rd party to manage the IT at a company is another.

Now that the risk management strategy has been defined, each component of the strategy contributes to the overall cost of security. Special data will need special handling and protection, but what about everything else? It is going to require careful consideration on an individual basis. Weighing the cost of the equipment against the cost of a breach is a great starting point. A solid place to begin is by comparing the expense of the necessary equipment against the potential losses that could result from a security breach. A data breach can be extremely expensive for a corporation monetarily and in terms of reputational harm. Governments can step in and impose fines and restrictions.

Another thing that will need to be considered is the likelihood of the event occurring. For instance, certain regions are subject to risks of natural disasters, while others will not be affected by them. If the company is in a region that does not, then it is possible that it will not attempt to minimize or transfer risk. A decision must be made regarding how cost and risk should be balanced. The cost of security, in general, is significant, but so is the cost to a company of a security breach, which could cost the company considerably more.

Review

Well done, you have completed the **Data Security Concepts** Practice Lab.

Summary

You completed the following exercises:

- Exercise 1 - Password Management for BIOS, UEFI, & Bootloader
- Exercise 2 - Data Storage and Encryption Paradigms
- Exercise 3 - Business Impact of Data Security

You should now have further knowledge of:

- BIOS/UEFI Password
- Bootloader Password
- Physical Location & Retention Policies
- On-site Data Storage
- Off-site Data Storage
- Encryption
- Encryption Algorithms
- Data Value Prioritization
- Data Lifecycle Management
- Cost of Security Vs. Risk

Feedback

Shut down all virtual machines used in this lab. Alternatively, you can log out of the lab platform.